

OPERATION BLACK POLICY

Reporte Ejecutivo de Red Team

Clasificacion:	CONFIDENCIAL — Uso educativo
Adversario simulado:	APT28 (Fancy Bear) — GRU Rusia
Objetivo:	Multi-Forest — atackcorp.local · corp.local · ext.local
Fechas:	31 Mayo 2026 — 02 Junio 2026
Operador:	Adrian Camacho
Estado:	COMPLETADO — 5/5 Fases

1. Resumen Ejecutivo

BLACK POLICY demostro que un entorno multi-forest con Forest Trusts bidireccionales puede comprometerse en su totalidad partiendo de una sola cuenta de helpdesk. Los tres forests (atackcorp.local, corp.local, ext.local) fueron comprometidos mediante SID History Injection, Targeted Kerberoasting cross-forest, credential exposure en shares SMB y GPO Abuse. Se extrajo el hash krbtgt de los tres dominios y se establecio persistencia C2 en dos equipos.

Attack Path

Paso	Tecnica	Resultado
1	Cross-Forest Kerberoasting + Recon	corp_svc:CorpSvc2024! + ext_svc:ExtSvc2024!
2	SID History Injection (DSInternals)	child.user = Domain Admin atackcorp.local
3	DCSync x3 (atackcorp/corp/ext)	krbtgt NTLM de 3 forests
4	GPO Abuse (pyGPOAbuse + WriteDACL)	helpdesk.ruiz admin local WKSTN-01
5	Sliver C2 + OPSEC Cleanup	Beacons WKSTN-01 + DC-02 · Crown Jewel exfiltrado

2. Crown Jewels Capturados

#	Objetivo	Resultado	Impacto
1	DA atackcorp.local via GPO	helpdesk.ruiz admin WKSTN-01	CRITICO
2	DA atackcorp.local via SID History	child.user = DA via DSInternals	CRITICO
3	DA corp.local	corp.admin:CorpAdmin2024! · krbtgt NTLM	CRITICO
4	DA ext.local	ext.admin:ExtAdmin2024! · krbtgt NTLM	CRITICO
5	Crown Jewel: IPO_strategy_2026.txt	Estrategia corporativa TOP SECRET exfiltrada	CRITICO
6	Beacon C2 dual	WKSTN-01 + DC-02 (black_policy_*)	ALTO

3. Fases de la Operacion

Fase 01 — Reconnaissance [T1558.003 / T1135]

Enumeracion multi-forest via LDAP. Cross-Forest Kerberoasting de corp_svc (corp.local) y ext_svc (ext.local). IT-Scripts share exponia credenciales backup_svc:Backup2024! y sa:SQLsa2026! en historial PowerShell y scripts de despliegue.

Fase 02 — SID History Injection [T1134.005]

DSInternals v4.14 Add-ADDBSidHistory inyecto el SID del grupo Domain Admins de atackcorp.local en el atributo sidHistory de child.user (child.atackcorp.local). child.user autentico con KDC de atackcorp.local como Domain Admin. DCSync extrajo krbtgt atackcorp.local: d5237a2e... (NTLM).

Fase 03 — Cross-Forest Trust Abuse [T1482 / T1003.006]

Targeted Kerberoasting de corp_svc via GenericAll de john.smith. corp.admin comprometido → DCSync corp.local krbtgt: 3e30210f... Ext-Data share exponia credenciales ext.admin en texto claro. DCSync ext.local krbtgt: 5c8afa0a...

Fase 04 — GPO Abuse Cross-Forest [T1484.001]

helpdesk.ruiz tenia WriteDACL sobre GPO IT-Baseline (atackcorp.local). dacedit otorgo FullControl a helpdesk.ruiz sobre la GPO. pyGPOAbuse creo ScheduledTask via SYSVOL ejecutando net localgroup. helpdesk.ruiz convertido en admin local de WKSTN-01 tras gpupdate.

Fase 05 — C2 + OPSEC Cleanup [T1071.001 / T1070]

Beacon black_policy_wkstn01 (WKSTN-01, helpdesk.ruiz) y black_policy_dc02 (DC-02, corp.admin) establecidos via Sliver HTTPS. IPO_strategy_2026.txt exfiltrado desde Enterprise-Strategy share. OPSEC cleanup: DACL GPO restaurado, ScheduledTask eliminada, sidHistory eliminado via bloodyAD.

4. MITRE ATT&CK; Coverage

Tactica	Tecnica	ID	Estado
Reconnaissance	Network Service Discovery + LDAP enum	T1046, T1135	■
Credential Access	Cross-Forest Kerberoasting	T1558.003	■
Privilege Escalation	SID History Injection	T1134.005	■
Discovery	Domain Trust Discovery	T1482	■
Credential Access	DCSync x3 forests	T1003.006	■
Privilege Escalation	GPO Modification (WriteDACL)	T1484.001	■
Persistence	Scheduled Task via GPO	T1053.005	■
Command & Control	Sliver HTTP/mTLS beacons	T1071.001	■
Exfiltration	Data from Network Share	T1039	■
Defense Evasion	Indicator Removal + DACL restore	T1070	■

5. Hallazgos Criticos y Recomendaciones

H-01 — Forest Trusts sin SID Filtering [CRITICO]

Descripcion: Los Forest Trusts entre attackcorp.local, corp.local y ext.local tenian SID Filtering deshabilitado. Esto permitio que el SID de Domain Admins de attackcorp.local fuera aceptado en el TGT de child.user.

Recomendacion: Habilitar SID Filtering en todos los Forest Trusts. Revisar si es necesario tenerlo deshabilitado.

H-02 — Credenciales en shares SMB (IT-Scripts) [CRITICO]

Descripcion: El share IT-Scripts exponia credenciales de backup_svc, sa y webapp_db en scripts PowerShell y en el historial de comandos del Administrador.

Recomendacion: Eliminar credenciales hardcodeadas en scripts. Usar secretos gestionados (Azure KeyVault, CyberArk). Restringir acceso a shares de scripts.

H-03 — WriteDACL excesivo sobre GPOs [CRITICO]

Descripcion: helpdesk.ruiz tenia WriteDACL sobre la GPO IT-Baseline, permitiendo modificar la GPO y desplegar codigo arbitrario en todos los equipos del scope.

Recomendacion: Auditar permisos sobre GPOs. Solo Domain Admins y Group Policy Creator Owners deben tener permisos de escritura sobre GPOs.

H-04 — Credential exposure en share Ext-Data [ALTO]

Descripcion: El share Ext-Data en DC-04 contenia un archivo credentials_backup.txt con ext.admin en texto claro, accesible via Forest Trust sin autenticacion adicional.

Recomendacion: Eliminar archivos de credenciales de shares. Revisar permisos de acceso cross-forest en shares.

6. Lecciones Aprendidas (seleccion)

L-01: Evil-WinRM crea Network Logon (tipo 3) — Get-ADGroup cross-forest y otros cmdlets AD fallan. Usar bloodyAD o impacket para operaciones cross-forest desde Kali.

L-02: bloodyAD v2.5.4 elimina sidHistory al verificar el atributo — usar DSInternals Add-ADDBSidHistory como alternativa robusta a mimikatz misc::addsid.

L-03: pyGPOAbuse es mas compatible que edicion directa de XML GPP en Windows 11 — el metodo XML requiere permisos SYSVOL adicionales.

L-04: DSInternals v4.14 requiere parar el servicio NTDS en el DC para escribir sidHistory offline — esto genera EventID 7036 (servicio detenido).

L-05: SID Filtering deshabilitado en Forest Trusts es un riesgo critico en produccion — cualquier DA en un forest hijo puede convertirse en DA del forest raiz via SID History.

L-06: El cleanup de sidHistory via bloodyAD puede fallar si la cuenta tiene privilegios elevados activos — reiniciar sesion de Kerberos del objetivo antes del cleanup.